GUÍA DEL ESTUDIANTE

Detectives de Ingeniería Social en Panadería Digital La Espiga

Paso 1 — Reúnete con tu equipo

Reúnete con el mismo equipo con el que has trabajado desde la Clase 1.

Paso 2 — Repasa tu marco de referencia antes de empezar

Antes de analizar cualquier escenario, ten a la vista estas tres tablas. Las vas a necesitar constantemente durante toda la actividad — no intentes memorizarlas, solo consúltalas cuando lo necesites.

Canales de ataque

Canal	Descripción
Correo electrónico	El canal más común hoy en día
Teléfono / llamadas de voz	Contacto directo por voz, con alta presión psicológica en tiempo real
SMS / mensajería instantánea	Mensajes de texto, WhatsApp, etc.
Redes sociales	Perfiles falsos, solicitudes de amistad, mensajes directos
En persona / físico	Contacto directo, cara a cara
Medios físicos removibles	USB u otros dispositivos dejados "por accidente"
Correo postal / documentos desechados	Menos común hoy, pero aún vigente

Técnicas más conocidas

Técnica	En qué consiste
Phishing / Spear phishing / Whaling	Correo fraudulento masivo (phishing), dirigido a una persona específica (spear phishing), o a un alto ejecutivo (whaling)
Vishing	Phishing por llamada telefónica
Smishing	Phishing por SMS
Pretexting	Inventar una historia o pretexto creíble para justificar la petición
Baiting	Ofrecer algo atractivo (archivo, USB) para que la víctima realice una acción
Quid pro quo	Ofrecer explícitamente un servicio o ayuda a cambio de algo (ej. datos de acceso)
Tailgating / Piggybacking	Seguir físicamente a alguien autorizado para entrar a un área restringida

Técnica	En qué consiste
Shoulder surfing	Mirar por encima del hombro de alguien mientras escribe información sensible
Dumpster diving	Revisar la basura en busca de información útil

Principios psicológicos que explota

Principio	En qué consiste
Autoridad	Obedecemos a quien percibimos con un cargo o poder superior
Urgencia / escasez	La presión del tiempo reduce nuestra capacidad de pensar con calma
Prueba social	Confiamos en algo si parece que "todos los demás" ya lo hicieron
Simpatía / afinidad	Es más fácil acceder a la petición de alguien que nos cae bien o nos ayuda
Reciprocidad	Sentimos la obligación de devolver un favor, incluso uno pequeño
Miedo	El miedo a una consecuencia negativa reduce el pensamiento crítico

Paso 3 — Estudia estos dos ejemplos ya resueltos

Antes de analizar tus propios escenarios, lee con calma estos dos casos ya analizados. Usa exactamente el mismo procedimiento de razonamiento cuando llegues al Paso 4.

Ejemplo resuelto 1 — Correo de phishing

```
De: Soporte Negocio Seguro <soporte@negocio-seguro-ayuda.com>
Para: empleado@panaderiadigitallaespiga.com
Asunto: ¡URGENTE! Su cuenta de administrador será suspendida en 2 horas

Estimado usuario,
Hemos detectado actividad inusual en su cuenta de administrador de
NegocioSeguro. Por motivos de seguridad, su acceso será suspendido
en las próximas 2 horas si no verifica sus datos de inmediato.
Haga clic aquí para verificar su cuenta y evitar la suspensión:
http://negoci0seguro-verificacion.com/login

Atentamente, El equipo de Soporte Técnico
```

Análisis, elemento por elemento:

1. **El remitente:** el dominio `negocio-seguro-ayuda.com` no es el dominio real de la empresa — un dominio parecido, pero no idéntico, rompe autenticidad (¿recuerdas la Clase 3?).
2. **La urgencia:** "su cuenta será suspendida en 2 horas" activa el principio psicológico de urgencia: busca que actúes rápido, sin pensar.
3. **El enlace:** `negoci0seguro-verificacion.com` — con un cero en lugar de la letra "o". El mismo tipo de engaño visual visto en la Clase 3.
4. **El saludo genérico:** "Estimado usuario" no usa tu nombre real — señal típica de un ataque masivo, no dirigido (phishing genérico, no spear phishing).

Elemento	Respuesta
Canal	Correo electrónico
Técnica	Phishing (genérico, no dirigido)
Principio psicológico	Urgencia (con apoyo de autoridad implícita del "soporte técnico")
Principio de seguridad comprometido	Autenticidad y Confidencialidad

Ejemplo resuelto 2 — Llamada telefónica (vishing + pretexting)

```
Atacante: "Buenas tardes, le habla Andrés Gómez, del área de Sistemas
de la Universidad. Estamos haciendo un mantenimiento urgente en el
portal académico y detectamos un problema con su usuario. ¿Me
confirma su usuario y contraseña para verificar que todo esté
funcionando correctamente antes de que quede bloqueado?"
```

Análisis:

1. **Autoridad:** se presenta con nombre propio y un cargo institucional específico, generando confianza inmediata.
2. **Pretexto creíble:** inventa una razón técnica plausible ("mantenimiento urgente") que justifica la petición extraña.
3. **La señal de alerta más importante:** ningún área de sistemas legítima necesita jamás que le digas tu contraseña en voz alta. Un sistema real nunca necesita "verificar" tu contraseña por teléfono — solo necesita que tú mismo la escribas en el sistema oficial.

Elemento	Respuesta
Canal	Teléfono
Técnica	Vishing + Pretexting
Principio psicológico	Autoridad, reforzada con una razón técnica creíble
Principio de seguridad comprometido	Confidencialidad (si se entrega la contraseña) y Autenticidad

Paso 4 — Analiza los seis escenarios en equipo

Copia esta plantilla en tu documento compartido:

# Escenario	¿Es ingeniería social? (Sí/No)	Canal	Técnica	Principio psicológico	Principio de seguridad comprometido	Señales de alerta identificadas
1						

2						
3						
4						
5						
6						

Analiza, en equipo, cada uno de los siguientes seis escenarios, aplicando el mismo procedimiento de los ejemplos resueltos del Paso 3, y completa la tabla:

ESCENARIO 1
De: soporte@negocio-seguro-ayuda.com
Asunto: Su cuenta será suspendida
"Estimado usuario, verifique sus datos aquí: negoci0seguro-verificacion.com, o su cuenta será suspendida en 2 horas."

ESCENARIO 2
Llamada telefónica: "Buenas, soy Andrés de Sistemas de la Universidad, necesito su usuario y contraseña para arreglar un problema urgente."

ESCENARIO 3
Correo real: "Hola Juan, este es un recordatorio de que tu contraseña de NegocioSeguro vence en 30 días. Puedes cambiarla ingresando normalmente a negocioseguro.com y yendo a 'Mi perfil > Seguridad'. No necesitas hacer nada si no quieres cambiarla todavía."

ESCENARIO 4
En la sala de descanso de la oficina aparece una memoria USB con una etiqueta que dice: "NÓMINA 2025 - CONFIDENCIAL - NO COMPARTIR"

ESCENARIO 5
Mensaje en red social: "¡Felicidades! Has sido preseleccionado para una vacante en una empresa reconocida. Tienes 2 horas para confirmar tu interés en este enlace antes de que se asigne a otro candidato."

ESCENARIO 6
Una persona con chaleco de "Servicio técnico" y una caja grande en los brazos le pide a un empleado que le sostenga la puerta de acceso restringido porque "se le van a caer los equipos".

Paso 5 — Diseña tu propio escenario

Ahora, como equipo, van a diseñar un escenario **de un caso real (de verdad, no inventado):** revisen su propio correo o mensajería (WhatsApp, redes sociales) en busca de algún mensaje sospechoso real que hayan recibido alguna vez. Analícenlo con el mismo formato de la tabla del Paso 4: canal, técnica, principio psicológico y principio de seguridad comprometido.

Elige un **canal** de la lista del Paso 2.

1. Elige una **técnica** de la lista del Paso 2.
2. Redacta el escenario completo (el mensaje, la llamada, o la situación física).
3. Identifica qué **señal de alerta** concreta

Agrega tu diseño a la misma plantilla de los 6 casos analizados como una nueva fila.

Paso 6 — Revisión final antes de entregar

Antes de dar por terminada la actividad, verifica que tu equipo tenga:

- [ ] La tabla de análisis de los seis escenarios, completa (canal, técnica, principio psicológico, principio de seguridad, señales de alerta).
- [ ] La correcta identificación del escenario legítimo (no todos son ataques).
- [ ] El escenario propio diseñado, con canal, técnica, descripción y señal de alerta.